Relatório de Laboratório — IAM com Microsoft Entra ID

Provisionamento por Script, Menor Privilégio e Ciclo de Vida de Identidades

Autor: Leonardo Garcia Santos
GitHub: github.com/leonardogsantos | LinkedIn: linkedin.com/in/leonardo-garcia-santos-a81a5a1b4
Data: 09 / 10 / 2026

1. Objetivo do Laboratório

Este relatório documenta a construção de um laboratório de IAM (Identity & Access Management) em um tenant do Microsoft Entra ID, utilizado para praticar três atividades centrais da gestão de acessos: o provisionamento de usuários e grupos por script, a aplicação do princípio de menor privilégio por meio de RBAC, e o ciclo de vida de identidades (entrada, mudança de área e saída de usuários). Em uma quarta etapa, o laboratório pratica o registro de autenticação multifator (MFA) e a análise de um token OpenID Connect.

O objetivo é demonstrar, na prática, competências de administração de usuários, grupos e permissões, e de automação de rotinas de acesso com PowerShell — habilidades centrais para a posição de Analista de Segurança da Informação júnior com foco em IAM.

Todos os usuários e dados usados neste laboratório são fictícios.

2. Ambiente

- Tenant do Microsoft Entra ID com licença gratuita (Entra ID Free).
- Máquina virtual Windows (WINDOWS-IAM-LAB), com Windows PowerShell 5.1.
- Módulos do Microsoft Graph PowerShell: Authentication, Users e Groups.
- Arquivos transferidos do computador anfitrião para a VM por um servidor Apache local (XAMPP).
- Conta de administração do laboratório: admin-trial, única com a função de Administrador Global.

3. Etapa 1 — Usuários e Grupos por Script

O que foi feito

O script 01-criar-usuarios-grupos.ps1 lê o arquivo usuarios.csv e executa, de forma automática:

- criação de cada usuário que ainda não existe, com senha temporária aleatória e troca obrigatória no primeiro login;
- definição do local de uso (necessário para atribuir licenças no futuro) e do departamento;
- criação dos grupos de segurança e inclusão de cada usuário no grupo da sua área;
- execução repetível: se o script for rodado novamente, ele reconhece o que já existe e não duplica nada.

Estrutura do CSV

Nome	Usuário	Departamento	Grupo
Ana (TI)	ana.ti	TI	GRP-TI
Bruno (TI)	bruno.ti	TI	GRP-TI
Carla (Financeiro)	carla.fin	Financeiro	GRP-Financeiro
Diego (Financeiro)	diego.fin	Financeiro	GRP-Financeiro
Elisa (Auditoria)	elisa.aud	Auditoria	GRP-Auditoria
Fabio (Auditoria)	fabio.aud	Auditoria	GRP-Auditoria

Comando executado

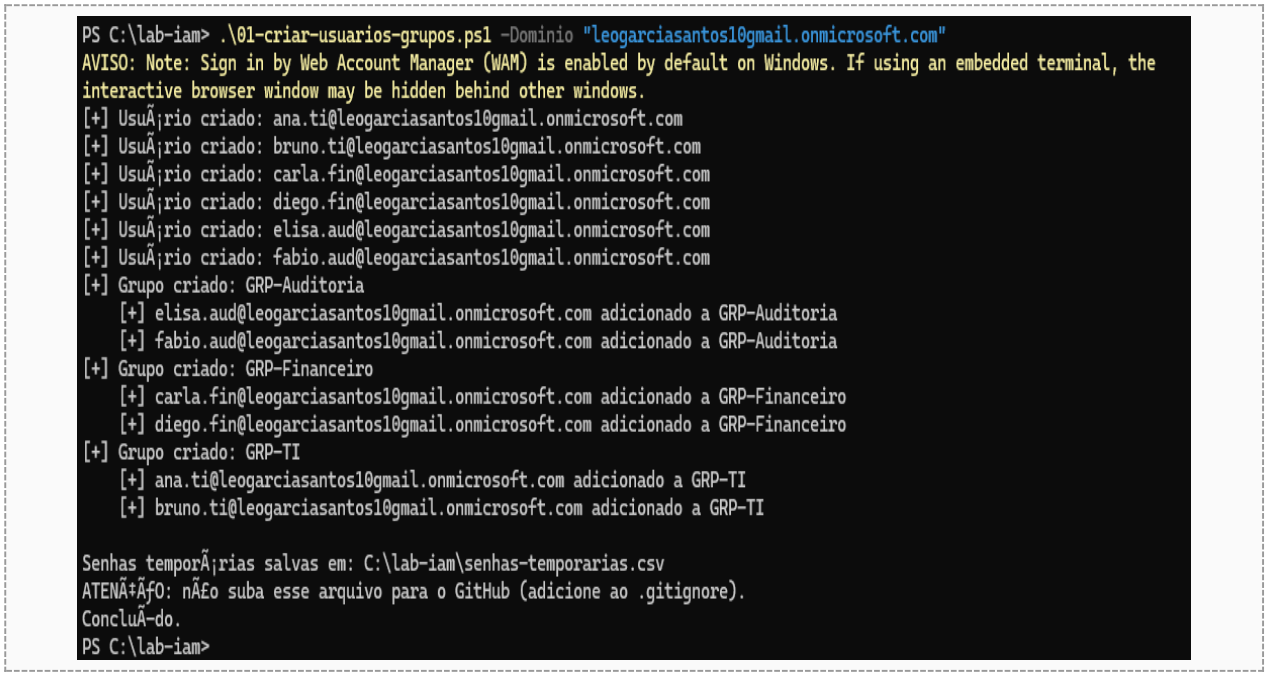
```
.\01-criar-usuarios-grupos.ps1 -Dominio "<dominio>.onmicrosoft.com"
```

Saída resumida:

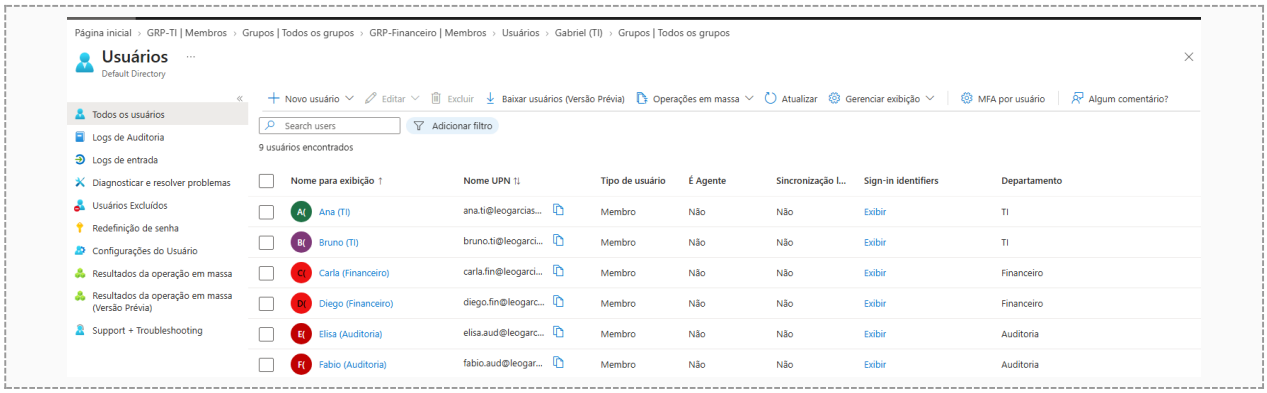
```
[+] Usuário criado: ana.ti@<dominio>.onmicrosoft.com
[+] Usuário criado: bruno.ti@<dominio>.onmicrosoft.com
...
[+] Grupo criado: GRP-TI
    [+] ana.ti@<dominio>.onmicrosoft.com adicionado a GRP-TI
    [+] bruno.ti@<dominio>.onmicrosoft.com adicionado a GRP-TI
...
Concluído.
```

O script gera, na própria VM, um arquivo com as senhas temporárias, que não é versionado no repositório.

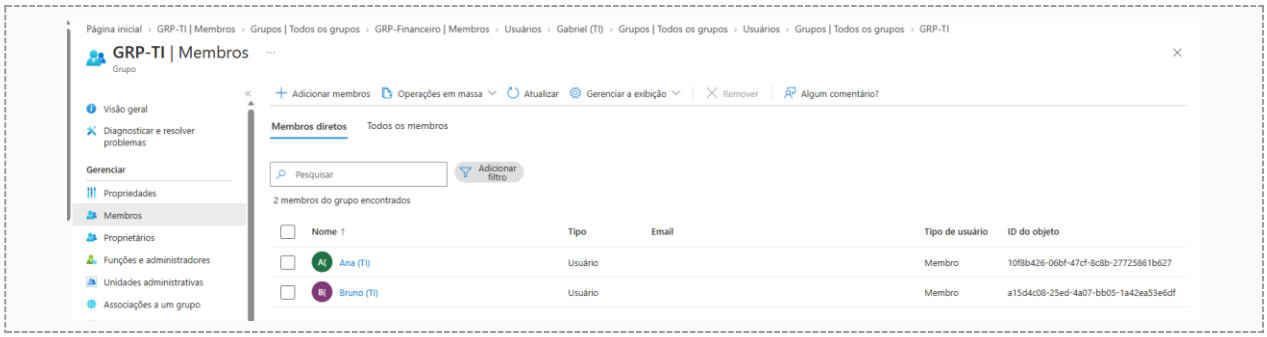
Evidência (print da execução do script no terminal):

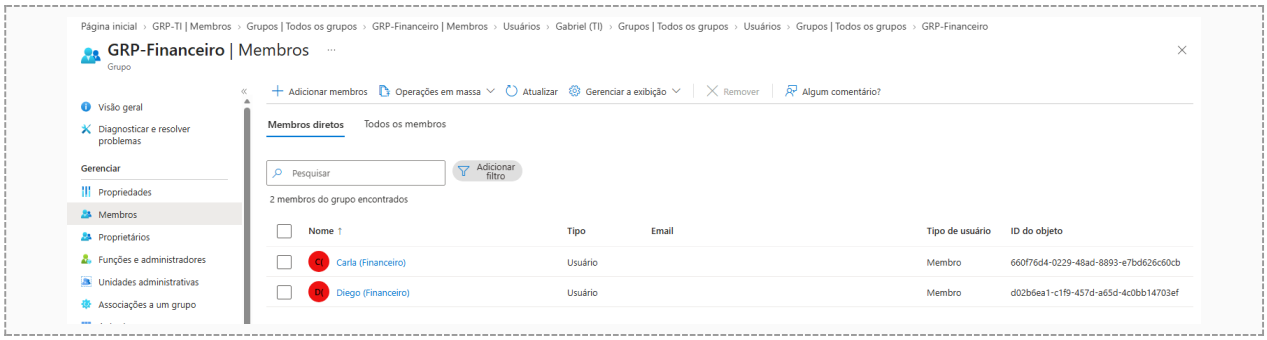


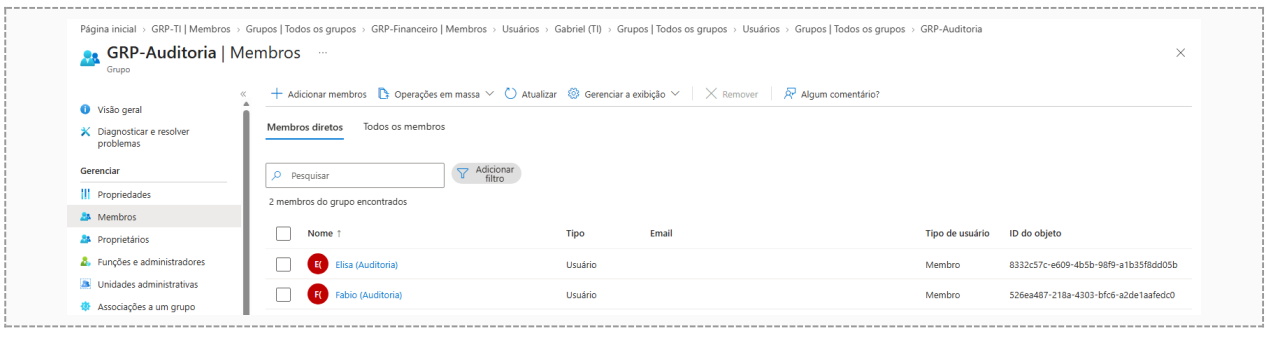
Evidência (print da lista de usuários no portal, com a coluna Departamento):



Evidência (print dos membros de cada grupo):







4. Etapa 2 — RBAC com Menor Privilégio

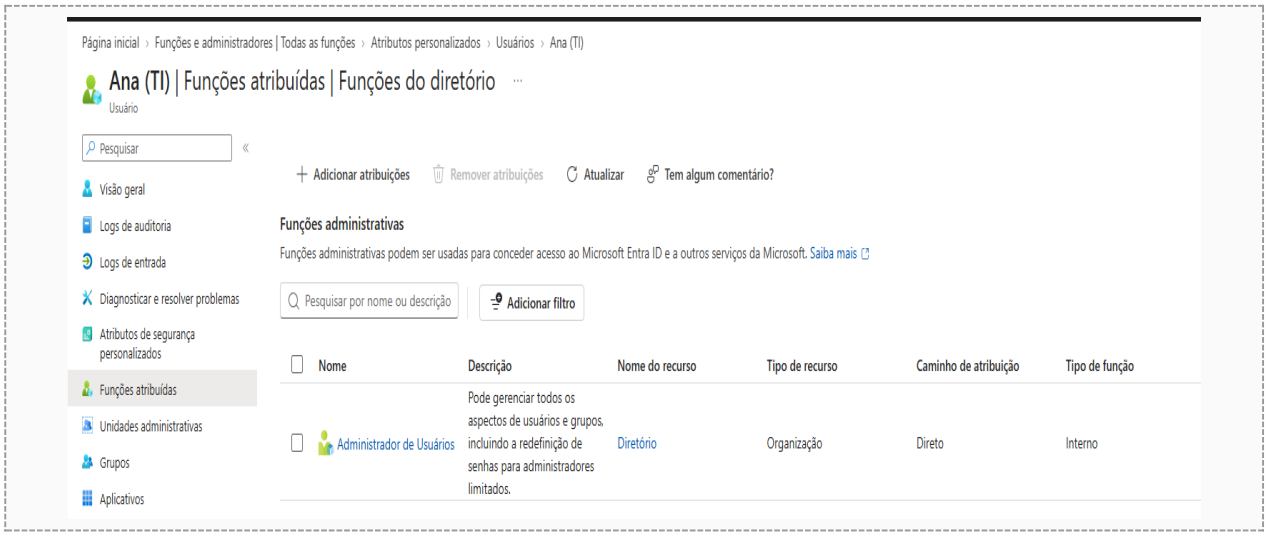
O que foi feito

Cada perfil recebeu apenas a função do Entra ID necessária para a sua tarefa. Somente a conta admin-trial mantém o poder de Administrador Global.

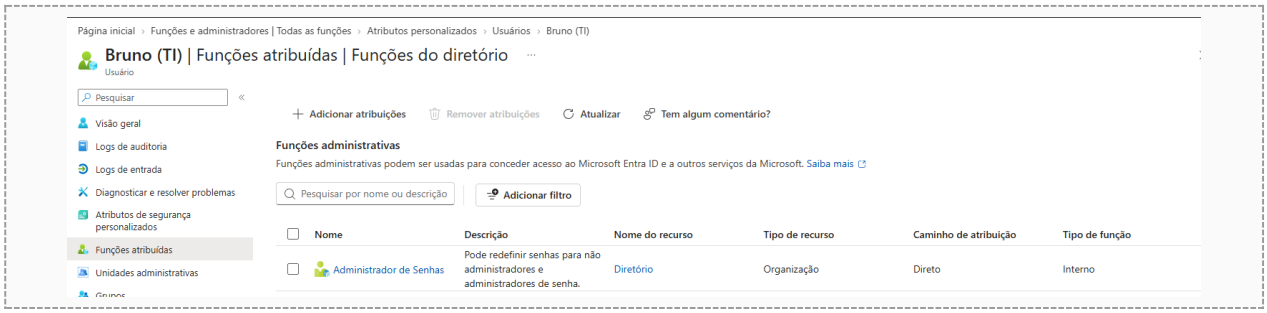
Perfil	Usuário	Função no Entra ID	O que pode	O que não pode
TI (gestão de usuários)	ana.ti	Administrador de Usuários	Criar e gerenciar usuários e grupos	Alterar configurações do tenant
TI (suporte)	bruno.ti	Administrador de senhas	Redefinir senhas de usuários comuns	Criar ou excluir usuários
Auditoria	elisa.aud	Leitor Global	Consultar configurações e dados do diretório	Alterar qualquer coisa
Financeiro e Auditoria	carla.fin, diego.fin, fabio.aud	Nenhuma função administrativa	Usar os próprios acessos	Qualquer ação administrativa
Conta de administração	admin-trial	Administrador Global (único)	Administrar o tenant	—

Critério de escolha: cada função é o menor conjunto de permissões que cumpre a tarefa do perfil. As funções foram atribuídas diretamente aos usuários, com escopo no diretório.

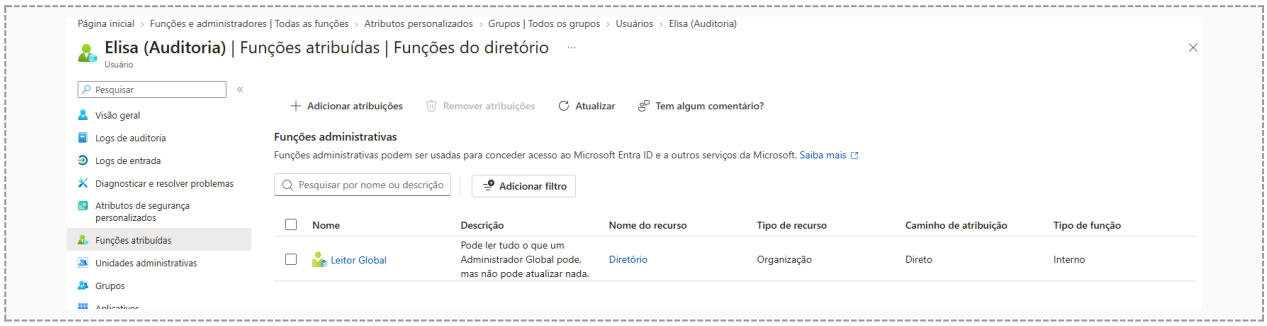
Evidência (print da função Administrador de Usuários, aba Atribuições):



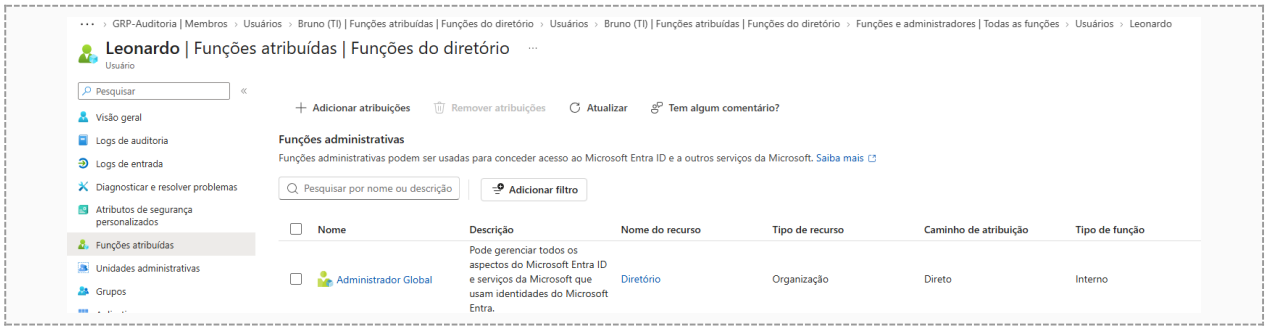
Evidência (print da função atribuída ao Bruno):



Evidência (print da função Leitor Global):



Evidência (print do Administrador Global):



5. Etapa 3 — Ciclo de Vida de Identidades (Joiner, Mover e Leaver)

O que foi feito

O script 02-jml.ps1 executa as três ações do ciclo de vida de um usuário e registra cada uma no arquivo jml-log.csv (data e hora, ação, usuário e detalhe). Foi usado um funcionário fictício, o Gabriel.

Ação	O que o script faz
Joiner (entrada)	Cria o usuário, define o departamento e o adiciona ao grupo da área
Mover (mudança de área)	Atualiza o departamento, remove o usuário dos grupos antigos e o adiciona ao grupo novo. Avisa se ainda houver funções administrativas atribuídas

Ação	O que o script faz
Leaver (saída)	Desativa a conta, revoga as sessões ativas e remove o usuário de todos os grupos. A conta não é excluída, para manter a trilha de auditoria

Na mudança de área, o acesso antigo é removido para evitar o acúmulo de privilégios.

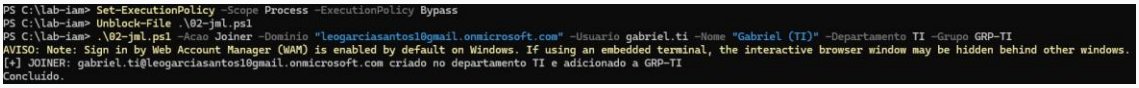
Comandos executados

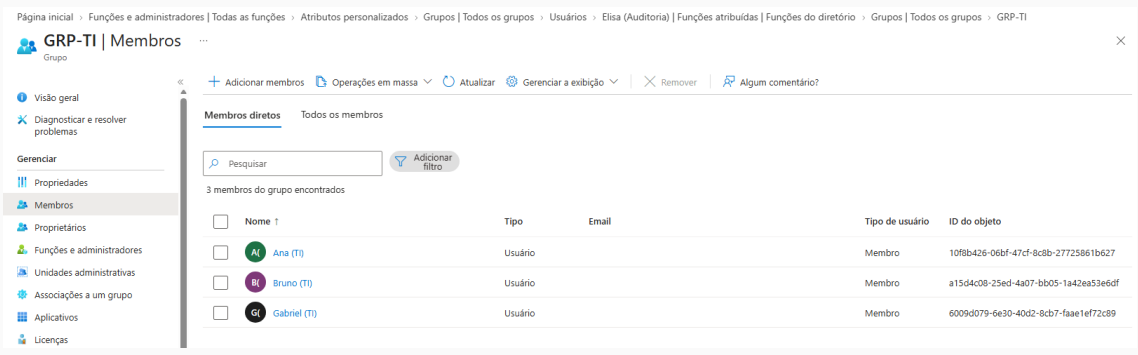
```
.\02-jml.ps1 -Acao Joiner -Dominio "<dominio>.onmicrosoft.com" -Usuario gabriel.ti
-Nome "Gabriel (TI)" -Departamento TI -Grupo GRP-TI
.\02-jml.ps1 -Acao Mover  -Dominio "<dominio>.onmicrosoft.com" -Usuario gabriel.ti
-Departamento Financeiro -Grupo GRP-Financeiro
.\02-jml.ps1 -Acao Leaver -Dominio "<dominio>.onmicrosoft.com" -Usuario gabriel.ti
```

Saída do Leaver:

```
    [-] Conta desativada
    [-] Sessões ativas revogadas
    [-] Removido do grupo: GRP-Financeiro
[x] LEAVER: gabriel.ti@<dominio>.onmicrosoft.com desativado; 1 grupo(s)
removido(s). A conta foi mantida para auditoria.
```

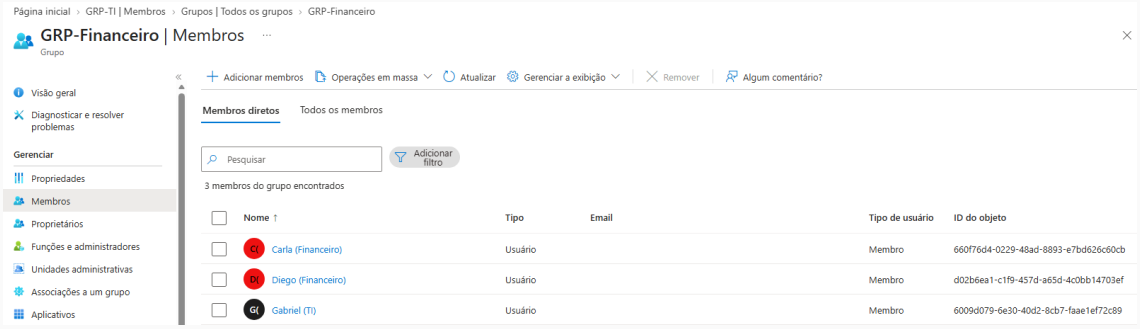
Evidência — Joiner (print do terminal e do portal):





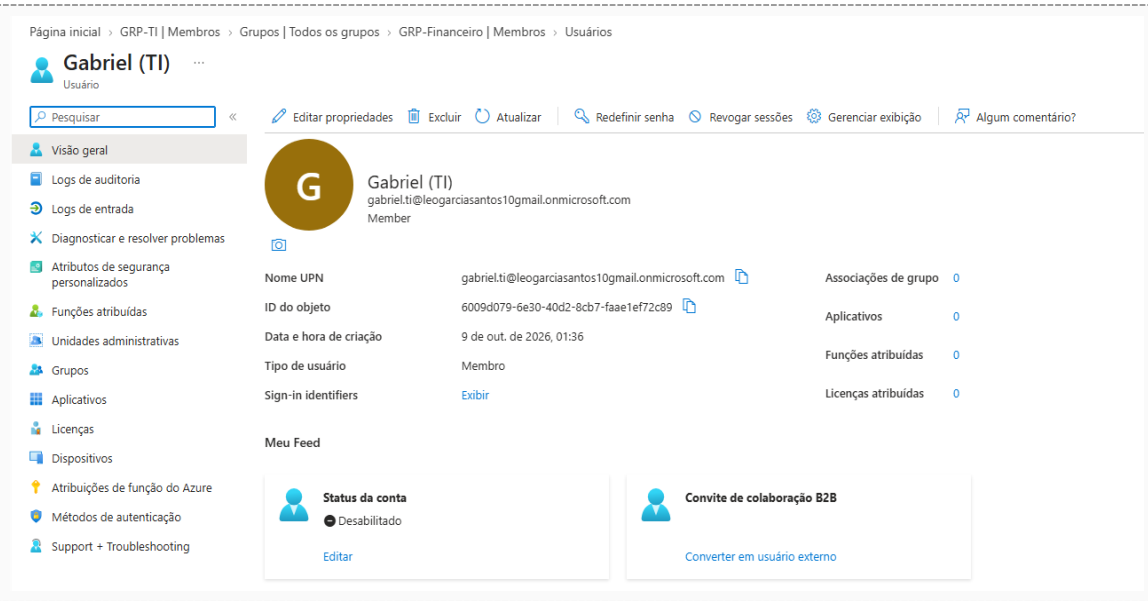
Evidência — Mover (print do terminal e do portal):

```
PS C:\lab-iam> .\02-jml.ps1 -Acao Mover -Dominio "leogarciasantos10gmail.onmicrosoft.com" -Usuario gabriel.ti -Departamento Financeiro -Grupo GRP-Financeiro
AVISO: Note: Sign in by Web Account Manager (WAM) is enabled by default on Windows. If using an embedded terminal, the interactive browser window may be hidden behind other windows.
    [-] Removido do grupo: GRP-TI
    [+] Adicionado ao grupo: GRP-Financeiro
[~] MOVER: gabriel.ti@leogarciasantos10gmail.onmicrosoft.com agora em Financeiro (GRP-Financeiro); 1 grupo(s) antigo(s) removido(s)
Concluído.
```

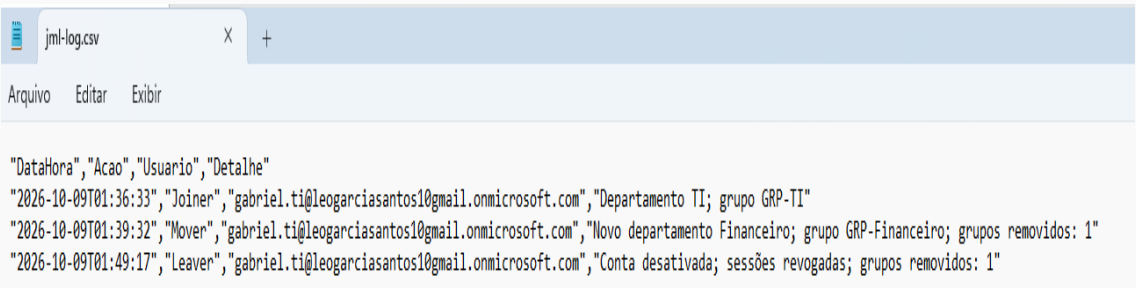


Evidência — Leaver (print do terminal e do portal):

```
PS C:\lab-iam>    .\02-jml-dois.ps1 -Acao Leaver -Dominio "leogarciasantos10gmail.onmicrosoft.com" -Usuario gabriel.ti
    [-] Conta desativada
    [-] Sessões ativas revogadas
    [-] Removido do grupo: GRP-Financeiro
[x] LEAVER: gabriel.ti@leogarciasantos10gmail.onmicrosoft.com desativado; 1 grupo(s) removido(s). A conta foi mantida para auditoria.
AVISO: Failed to clear the persisted MSAL token cache during Disconnect-MgGraph: The authority (including the tenant ID) must be in a well-formed URI format.
Nome do parâmetro: authority
Concluído.
```



Evidência (print do log de ações):



6. Etapa 4 — MFA e OAuth 2.0 / OpenID Connect

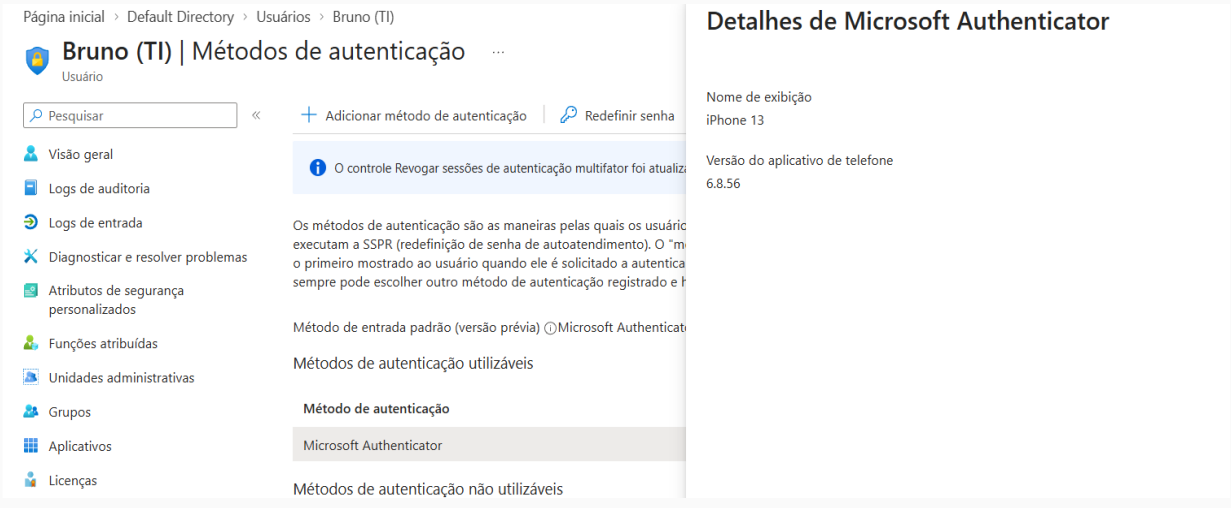
O que foi feito

Nesta etapa foram praticados dois temas de autenticação no tenant gratuito: o registro de autenticação multifator (MFA) com o aplicativo Microsoft Authenticator e o registro de um aplicativo no Entra ID que usa OAuth 2.0 e OpenID Connect, com a análise de um token de ID.

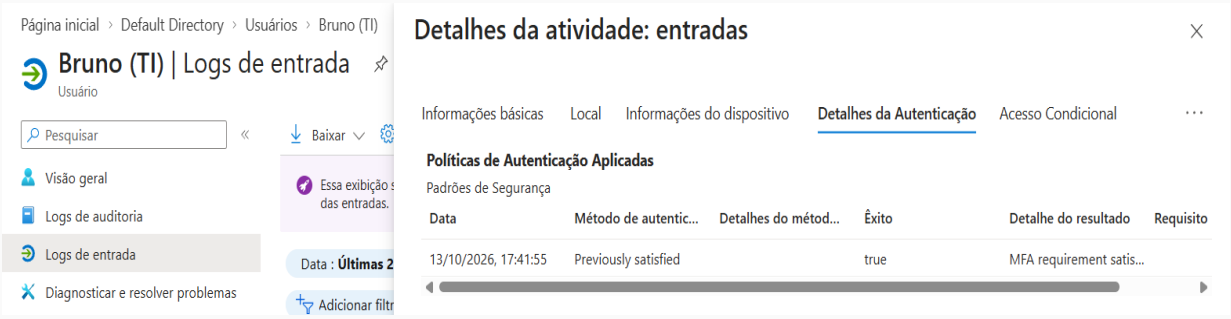
Parte A — MFA com Microsoft Authenticator

O tenant utiliza os padrões de segurança (Security Defaults) do Entra ID, que exigem o registro de MFA dos usuários e a autenticação multifator dos administradores. O usuário bruno.ti, que tem a função de Administrador de Senhas, passou pelo registro do MFA no primeiro login. O método registrado foi o Microsoft Authenticator, com aprovação por notificação no celular.

Evidência (print do método registrado):



Evidência (print do log de entrada):



Parte B — Aplicativo com OAuth 2.0 e OpenID Connect

Foi registrado o aplicativo lab-iam-oidc, de locatário único, com o URI de redirecionamento https://jwt.ms, site da Microsoft que decodifica tokens. Para o teste, foi habilitado o recebimento de tokens de ID (fluxo implícito).

A requisição de autorização abaixo, enviada ao endpoint OAuth 2.0 do tenant, devolveu um token de ID ao jwt.ms depois do login do usuário bruno.ti:

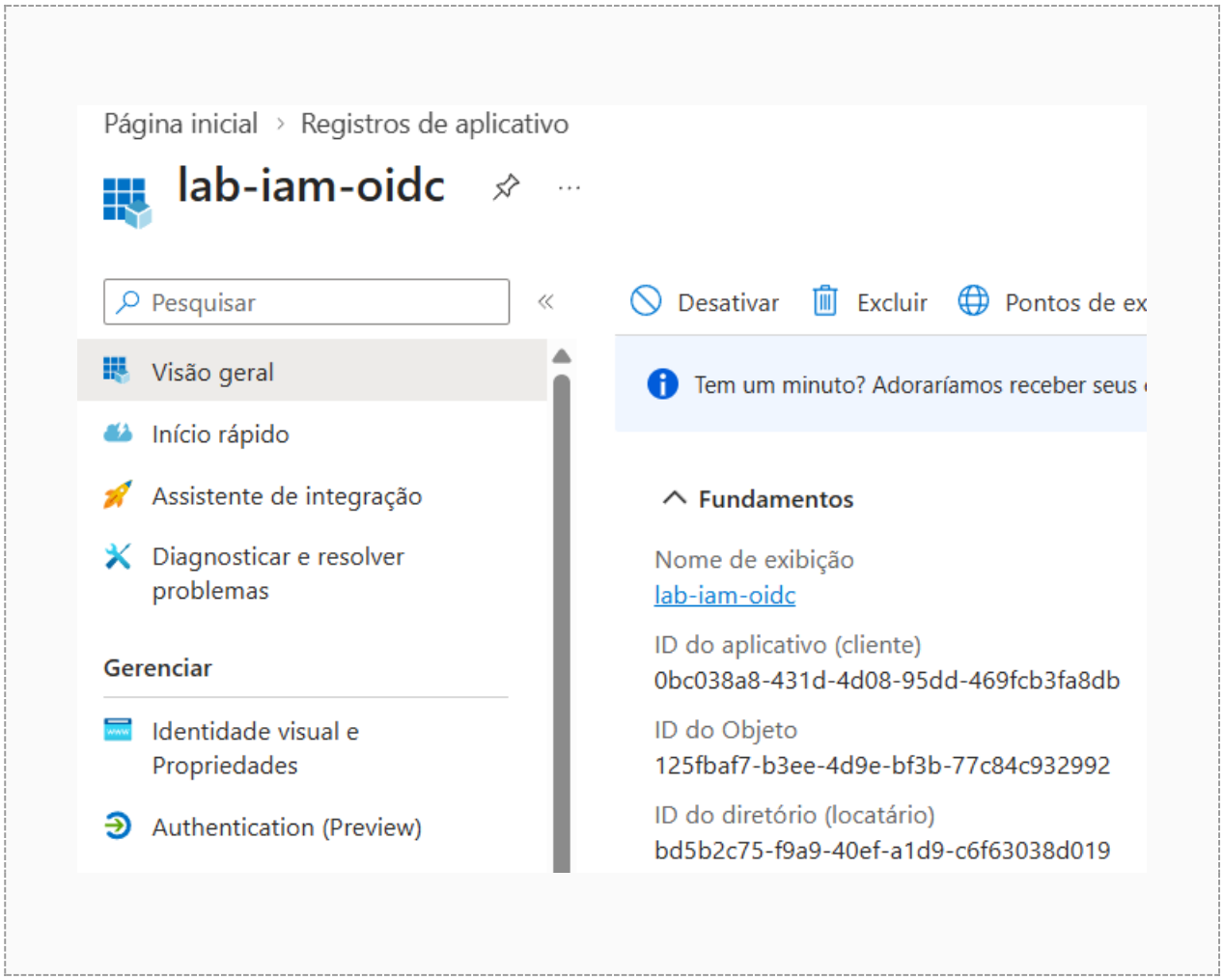
```
https://login.microsoftonline.com/<ID-DO-
DIRETORIO>/oauth2/v2.0/authorize?client_id=<ID-DO-
APLICATIVO>&response_type=id_token&redirect_uri=https%3A%2F%2Fjwt.ms&scope=openid%2
0profile%20email&response_mode=fragment&nonce=1234
```

No token decodificado foram analisados os campos iss (emissor, o tenant), aud (o aplicativo registrado), tid (o locatário), name e preferred_username (o usuário), iat e exp (emissão e validade, de pouco mais de uma hora) e ver (versão 2.0). O documento de metadados do OpenID Connect do tenant lista os endpoints de autorização e de token, o emissor e as chaves de assinatura (jwks_uri).

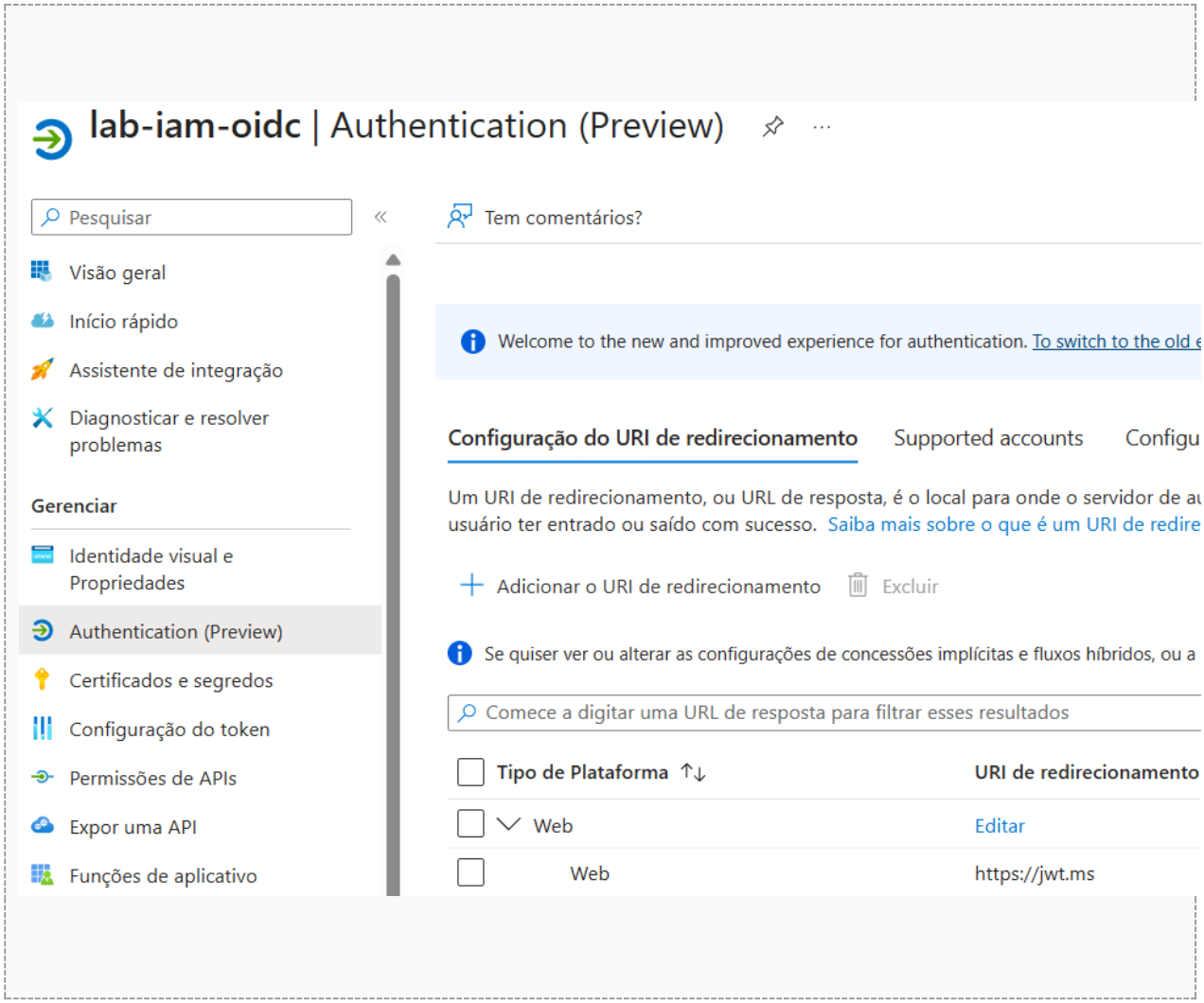
O token de ID obtido neste teste não trouxe o campo amr (método de autenticação). Por isso, a evidência do MFA são os métodos de autenticação do usuário e os detalhes da autenticação no log de entrada, e não o token.

Ao final, o recebimento de tokens de ID (fluxo implícito) foi desabilitado, por ser um fluxo legado e desnecessário depois do teste.

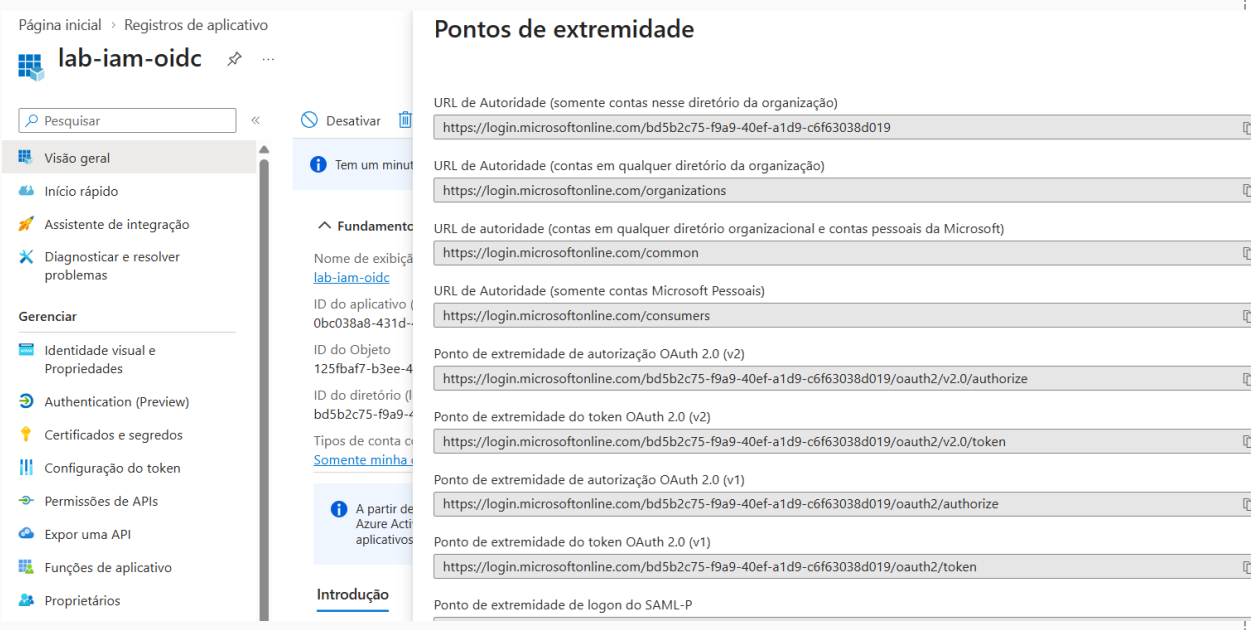
Evidência (print do registro do aplicativo):



Evidência (print da configuração de autenticação):



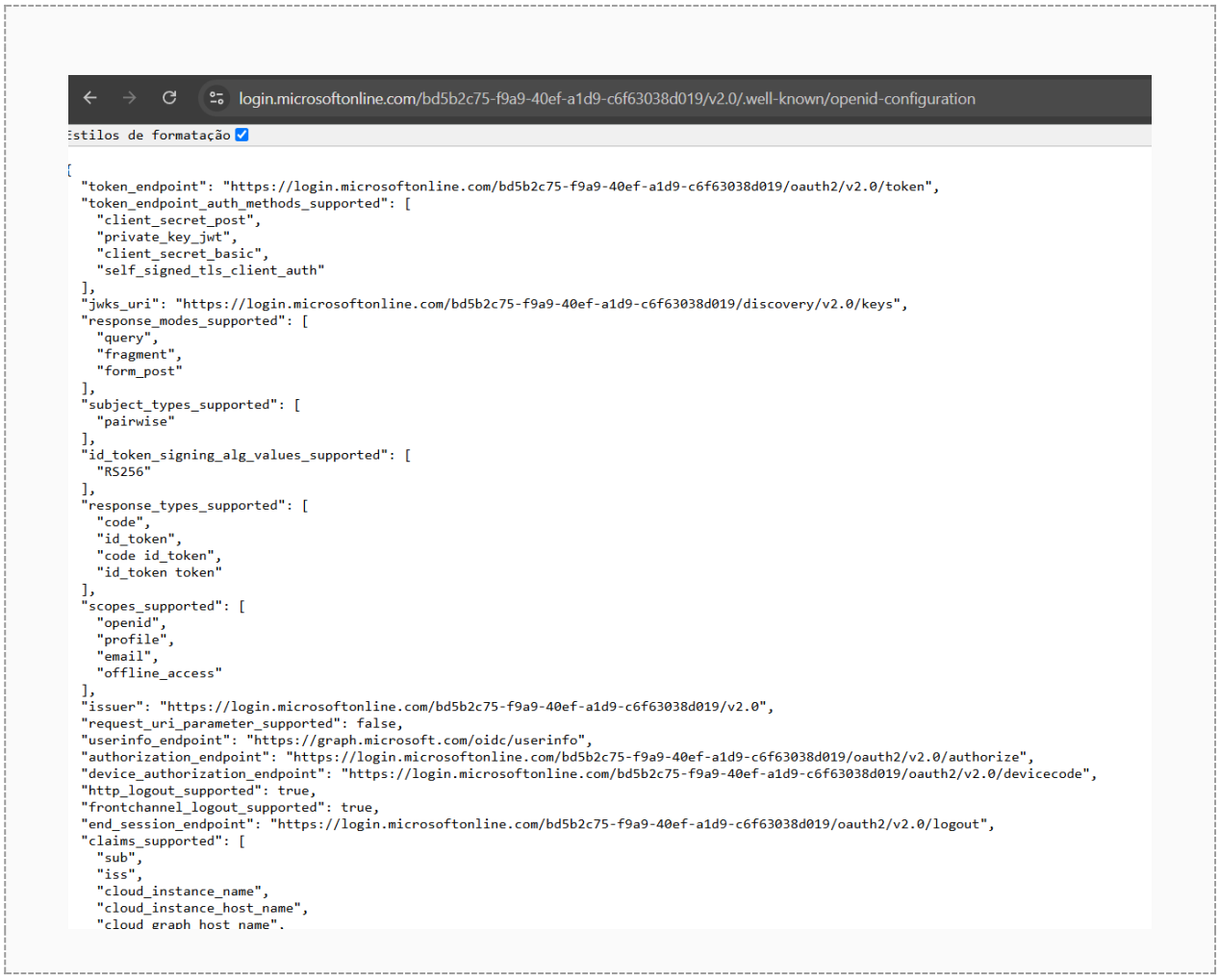
Evidência (print dos pontos de extremidade):



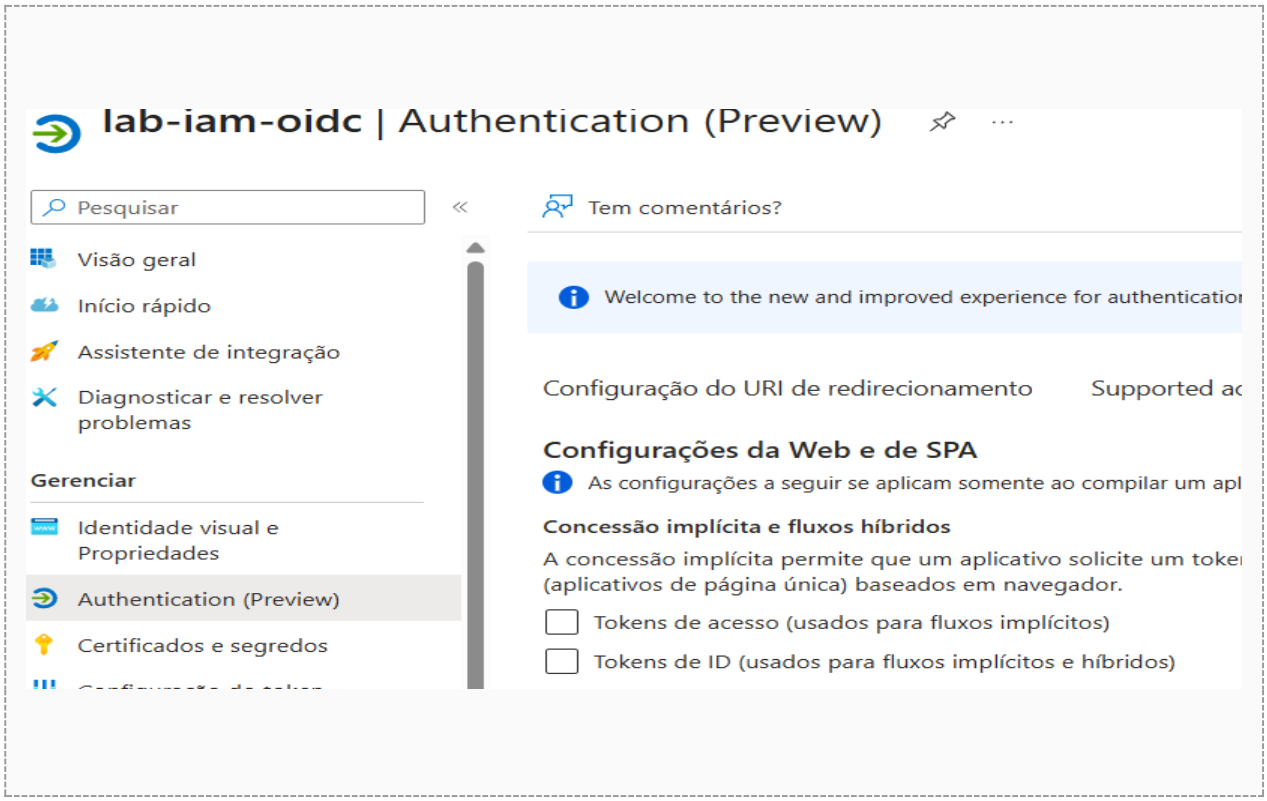
Evidência (print do token de ID decodificado):


```
  "aud": "0bc038a8-431d-4d08-95dd-469fcb3fa8db",
  "iss": "https://login.microsoftonline.com/bd5b2c75-f9a9-40ef-a1d9-c6f63038d019/v2.0",
  "iat": 1791925011,
  "nbf": 1791925011,
  "exp": 1791928911,
  "aio":
"AYQAe/8eAAAAjmeuo2vZCha5XMZ+ukf7fRXCdo4tGvhVmq6gAjbnQ4eDtCR+ilIqwqALYu3agdJYLA8vkHhqUfPf2/e7HxHTdephUSRQJvfC9+UaaJV2LE6KtOVsBrJvep5ou
V94Ll7E947XlFpk6ILJ5yVb83kTgu7F0OwOzLyLfxc4GHUyEfM=",
  "cc":
"CmA7yrFd8/JArGV7cjIkQhVxZ2K7MDyw6dBOhAErb/wJLH0H1xlP8yKJvOAXHtsshbhV5LKtW8ncPuEgNCgw58GDh9H795jCZDcR0g5jqlTTg7VVdGtyFPYWFd1j4aBbtE8SJ
mxlb2dhcmNpYXNhbnRvczEwZ21haWwub25taWNyb3NvZnQuY29tGhIKELO5cqIIpVhDtEHRtgOxzO0iEgoQDzl3rGFy9kOG9ghgspgvADICU0E4AUIJCQCPvUZqKd9I",
  "name": "Bruno (TI)",
  "nonce": "1234",
  "oid": "a15d4c08-25ed-4a07-bb05-1a42ea53e6df",
  "preferred_username": "bruno.ti@leogarciasantos10gmail.onmicrosoft.com",
```

Evidência (print do documento de metadados do OpenID Connect):



Evidência (print dos tokens de ID desabilitados):



7. Decisões de Segurança

- Nenhuma senha é escrita no código nem no CSV de entrada. As senhas temporárias são aleatórias, com troca obrigatória no primeiro login, e ficam em um arquivo local excluído do repositório pelo .gitignore.
- As funções administrativas seguem o menor privilégio, e apenas uma conta tem o poder máximo.
- Na saída de um usuário, a conta é desativada e as sessões são revogadas, sem exclusão imediata, o que preserva a trilha de auditoria.
- Na mudança de área, os acessos antigos são removidos, evitando o acúmulo de privilégios.
- Todas as ações do ciclo de vida são registradas em log.
- O MFA com o Microsoft Authenticator protege contas com função administrativa, como a do Bruno, contra o uso de uma senha comprometida.
- O fluxo implícito do aplicativo de teste foi habilitado apenas para gerar o token e desabilitado em seguida.

8. Problemas Encontrados e Soluções

Problema	Causa provável	Solução
A instalação do módulo ficava parada	O instalador do NuGet tentava instalar para todos os usuários e exigia administrador	Instalação com o parâmetro -Scope CurrentUser e uso de -Verbose para acompanhar o progresso

Problema	Causa provável	Solução
Erro AADSTS70008 (token expirado) no login	Janela de login do Windows (WAM) com sessão antiga	Login pelo navegador e opção de login por código de dispositivo (-CodigoDeDispositivo)
Erro de runspace ao revogar as sessões no Leaver	Falha do cmdlet tipado no Windows PowerShell 5.1	Troca por uma chamada direta à API do Microsoft Graph, com tratamento de erro
Acentos quebrados no terminal	O Windows PowerShell 5.1 lê o script com a codificação errada	Arquivos salvos em UTF-8 com BOM
Aviso ao encerrar a sessão sobre o cache de token	Efeito de desativar o login pelo WAM	Sem impacto no laboratório; apenas registrado

9. Conclusão

Este laboratório demonstrou, de ponta a ponta, a administração de identidades e acessos em um tenant do Microsoft Entra ID: provisionamento em lote por script, atribuição de funções com menor privilégio e gestão do ciclo de vida de um usuário, da entrada à saída, com registro das ações.

Entre os principais aprendizados práticos, destacam-se: automação de rotinas de acesso com Microsoft Graph PowerShell, scripts que podem ser repetidos sem duplicar objetos, a diferença entre desativar e excluir uma conta, e o diagnóstico de problemas de autenticação e de módulos em um ambiente real. A etapa 4 acrescentou a prática de autenticação multifator com o Microsoft Authenticator e a leitura de um token de ID OpenID Connect, ligando a gestão de acessos aos protocolos de autenticação.

9.1 — Próximos passos / melhorias futuras

- Privileged Identity Management (PIM): tornar a função de administrador elegível e temporária, com justificativa e MFA. Exige a licença Entra ID P2 e ainda não foi implementado.
- Conditional Access: exigir MFA para as funções administrativas.
- Revisão periódica de acessos dos grupos e das funções.
- Teste prático do menor privilégio, entrando com um usuário de suporte e verificando o que ele pode e não pode fazer.
- Análise de segregação de funções (SoD) entre os grupos.

Repositório do projeto: github.com/leonardogsantos/Entra-ID-iam-lab